UNIT 4 · TOPIC 4.2

Device Authentication Hardening

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. A system administrator stores user credentials in a database. Which of the following best identifies the primary purpose of hashing passwords before storing them?

- ○ A. To encrypt the password so that the administrator can decrypt and view it when needed.
- ○ B. To compress the password string in order to reduce database storage costs.
- ○ C. To produce a fixed-length value that cannot feasibly be reversed to reveal the original password.
- ○ D. To convert the password to Base64 encoding for safe transmission over a network.

2. Which of the following best identifies an example of multi-factor authentication (MFA)?

- ○ A. A user enters a password and then approves a push notification on a registered smartphone.
- ○ B. A user enters a password and then answers a security question.
- ○ C. A user enters a username and a password.
- ○ D. A user enters two different passwords on two successive login screens.

3. Which of the following authentication credentials is classified as a "something you are" factor?

- ○ A. A fingerprint scan.
- ○ B. A hardware security token that generates one-time codes.
- ○ C. A one-time passcode sent to a registered mobile phone via SMS.
- ○ D. A personal identification number (PIN).

4. An attacker breaches a web application's database and obtains the stored password records. The application stores passwords as bcrypt hashes. Which of the following best explains why hashing reduces the impact of this breach compared to storing plaintext passwords?

- ○ A. The bcrypt hashes are automatically re-encrypted on each database read, so the attacker's copy becomes invalid immediately after the breach.
- ○ B. Bcrypt hashes are protected by the database server's private key, preventing the attacker from reading them without that key.
- ○ C. The attacker cannot use the hash values directly to authenticate and must attempt computationally expensive offline cracking to recover any original passwords.
- ○ D. The hashes allow the organization to immediately identify which accounts were compromised because each hash is unique to one user.

5. At Aceshack, a junior sysadmin configures the shared drop-in workstation to lock an account after five consecutive failed login attempts. Which of the following best explains how this setting mitigates an online brute-force password attack?

- ○ A. It limits the number of guesses an attacker can make before access is blocked, making exhaustive trial-and-error impractical without triggering a lockout.
- ○ B. It encrypts the account's credentials after five failures, making them unreadable until an administrator unlocks the account.

○ C. It forces the attacker to switch to a different authentication protocol after five failed attempts, increasing the complexity of the attack.

○ D. It resets the account password automatically after five failures and sends a new credential to the account owner.

6. Aceshack is evaluating whether to require MFA on the shared drop-in workstation used by visiting remote workers. A manager asks why MFA would still be valuable even if a worker's password is already strong. Which of the following best explains MFA's risk-reduction benefit in this scenario?

○ A. MFA prevents password reuse across sites, ensuring a compromised password on one system cannot be used on another.

○ B. MFA requires an attacker to also control a second authentication factor, such as the user's phone or hardware token, which the attacker is unlikely to possess even if they have obtained the password.

○ C. MFA completely replaces the password with a stronger credential, removing the risk associated with password-based authentication.

○ D. MFA encrypts all traffic between the workstation and Aceshack's servers, preventing credential interception in transit.

7. A financial services firm uses hashed and salted passwords, enforces account lockout after three failed attempts, and requires SMS-based MFA for all employee logins. During a recent red-team exercise, testers demonstrated that SIM-swapping attacks could allow an adversary to intercept SMS codes. Which of the following best evaluates the firm's current authentication posture and identifies the most effective remediation?

○ A. The firm's controls are sufficient; bcrypt hashing and salting protect against all realistic attack vectors, including SIM-swapping.

○ B. The account lockout threshold of three attempts is too permissive; raising it to ten would eliminate the SIM-swapping vulnerability.

○ C. The firm should discontinue MFA and invest those resources in stronger minimum password length requirements and more frequent mandatory rotations.

○ D. SMS-based MFA is susceptible to SIM-swapping; replacing it with a phishing-resistant alternative, such as a TOTP authenticator app or a FIDO2 hardware key, preserves the layered approach while closing the demonstrated gap.

8. Two web applications are breached simultaneously and their password databases stolen. Application Kappa stored passwords as unsalted MD5 hashes. Application Lambda stored passwords using bcrypt with a unique per-user random salt. Which of the following best evaluates the relative exposure of each application's users, and explains why?

○ A. Lambda's users are at significantly lower risk, because unique salts defeat precomputed rainbow tables and bcrypt's tunable cost factor makes offline brute-force computationally expensive even for modern hardware.

○ B. Kappa's users are equally exposed, because MD5 and bcrypt are both one-way hashing algorithms, making reversal impossible regardless of salting.

○ C. Kappa's users are more secure because MD5 produces a shorter hash than bcrypt, which requires less storage and is therefore harder to target.

○ D. Both applications are equally vulnerable because all password hashes can eventually be reversed using quantum computing, negating any benefit from salting or algorithm choice.

9. A hospital security team must design authentication controls for clinical workstations shared by nurses across a shift. Requirements include: rapid re-authentication after brief inactivity (to avoid delays in patient care), prevention of unauthorized access if a nurse steps away, and protection if a visitor observes a nurse entering credentials. Which configuration best balances these competing requirements?

○ A. A complex 16-character password with a 30-minute inactivity lockout and no MFA.

- ○ B. A badge tap (possession factor) plus a short PIN (knowledge factor), with a 3-minute inactivity screen lock.
- ○ C. No password; rely entirely on physical access controls to the ward to prevent unauthorized use.
- ○ D. Fingerprint biometric only, with a 60-minute inactivity lockout.

10. Which of the following best identifies the defining characteristic of a "layered" authentication approach?

- ○ A. Storing multiple copies of a user's password hash across separate servers to prevent data loss.
- ○ B. Requiring credentials from two or more distinct factor categories so that compromising one layer alone is insufficient to gain access.
- ○ C. Asking a user to authenticate through the same credential type twice in succession during a single session.
- ○ D. Distributing authentication requests across multiple servers to improve login performance.

11. A system administrator wants to address two distinct vulnerabilities: (1) stolen hashed passwords from a breached database and (2) online brute-force guessing of active accounts. Which combination of controls directly targets both vulnerabilities?

- ○ A. Mandatory password complexity rules and a frequent password rotation schedule.
- ○ B. Intrusion detection logging and physical access controls to the server room.
- ○ C. MFA and a 90-day password expiration policy.
- ○ D. Password hashing with unique salts (to protect stored credentials) and account lockout (to block excessive login attempts).

12. A system is configured to lock an account after five failed login attempts and to notify the account owner via email when a lockout occurs. Which type of password attack does this control combination most directly address?

- ○ A. An online brute-force attack attempting many password guesses against a live login interface.
- ○ B. A pass-the-hash attack targeting cached NTLM credentials.
- ○ C. A rainbow table attack against a stolen password database.
- ○ D. A credential stuffing attack using one known password attempted against many different user accounts.

13. You are the junior sysadmin at Aceshack, configuring a new shared workstation in the lobby drop-in area used by visiting remote workers throughout the day. The workstation is left unattended between users. Which combination of local security settings best addresses both unauthorized access from the unattended workstation and password-based attacks against user accounts?

- ○ A. Disable account lockout to prevent legitimate remote workers from being locked out; do not enable MFA to keep login simple.
- ○ B. Account lockout after five failed attempts, minimum password length of 12 characters, and automatic screen lock after 10 minutes of inactivity.
- ○ C. Account lockout after 20 failed attempts and no screen lock, to reduce disruption for legitimate users who share the workstation.
- ○ D. Mandatory password rotation every seven days and no lockout policy, relying on complex passwords alone to deter unauthorized access.

14. An attacker purchases a list of verified username-and-password pairs from a previous breach at another organization. They attempt to use these credentials on a company's employee portal, deliberately submitting only one login attempt per account to avoid triggering lockout. Which combination of controls would most effectively neutralize this specific attack?

- ○ A. Account lockout after three failed attempts and a password complexity requirement of at least 10 characters.
- ○ B. Extended minimum password length and mandatory password expiration every 60 days.

○ C. MFA requiring a second factor for all logins, combined with anomalous-login alerting based on new device or geographic location.

○ D. An intrusion detection system configured to alert on any failed login attempts.

15. A security team identifies that a local web application is vulnerable to dictionary attacks, attackers can submit large numbers of common-word password guesses through the login form. Which combination of controls would most effectively reduce this vulnerability by targeting both the attacker's ability to attempt guesses and the likelihood that any guessed word matches a user's password?

○ A. Regular user security awareness training and a mandatory annual password reset.

○ B. Blocking remote access to the login page so that it is only accessible from the internal network.

○ C. Server-side AES-256 encryption of all stored password hashes.

○ D. Password complexity requirements that reject dictionary words and common patterns, combined with account lockout after a defined number of failed attempts.

16. A company's authentication policy specifies: (1) minimum 8-character passwords, (2) account lockout after 10 failed attempts, (3) SHA-1 password hashing with no salting. A security auditor flags this as insufficient. Which of the following best evaluates the most critical weakness in this layered policy and explains why it undermines the other controls?

○ A. Unsalted SHA-1 hashing is the most critical weakness, its speed enables billions of guesses per second offline, and the absence of salts makes precomputed rainbow tables effective, rendering the complexity and lockout controls meaningless if the database is breached.

○ B. The 8-character minimum is the critical weakness; raising it to 16 characters alone would resolve all identified deficiencies.

○ C. The lockout threshold of 10 is the primary weakness; reducing it to two would resolve the dominant vulnerability in this policy.

○ D. The absence of a mandatory password expiration schedule is the most critical missing control, as credentials never become invalid over time.

17. A corporate network's authentication policy includes: (1) bcrypt-hashed passwords with unique salts, (2) account lockout after five failed attempts, (3) SMS-based MFA for remote access only, (4) on-site workstations exempt from MFA. A penetration tester demonstrates that physical access to the office building, obtainable through tailgating, allows full system access without MFA. Which modification best closes this gap while maintaining the defense-in-depth approach?

○ A. Remove SMS-based MFA from remote access and rely solely on bcrypt hashing and lockout policies for all access.

○ B. Install CCTV surveillance cameras at all on-site workstations to deter unauthorized physical access.

○ C. Upgrade SMS MFA to a TOTP authenticator app for remote access only; no change to on-site exemption is needed.

○ D. Extend MFA to all access contexts, both on-site and remote, so that physical presence in the building is not sufficient to bypass the second authentication factor.

18. As junior sysadmin at Aceshack, you receive the following authentication requirements from the security manager for the shared drop-in workstation: (a) multiple authorized remote workers must each maintain individual accountability, (b) legitimate users accidentally locked out must be recoverable without a full support ticket, (c) a visitor who learns a worker's password must still not be able to log in, (d) the solution must align with NIST SP 800-63B guidance. Which combination of controls best satisfies all four requirements simultaneously?

- ○ A. A single shared generic account with a complex password rotated weekly; no lockout policy to prevent service disruption.
- ○ B. Individual user accounts with SMS-based MFA only, no lockout policy, and mandatory 30-day password expiration.
- ○ C. Individual user accounts with bcrypt-hashed passwords, account lockout with a self-service unlock option, and TOTP-based MFA (e.g., an authenticator app).
- ○ D. A shared generic account with fingerprint biometric authentication and a 20-attempt lockout threshold.